SecureOps AI

Intelligent threat detection and response - explained in plain language.

A guide to what the system does, where its data comes from, how its AI models decide what is dangerous, how well it actually performs on real attack data, and where it falls short.

In one sentence: SecureOps AI watches network traffic, spots attacks with rules and a machine-learning model, groups hundreds of warnings into a few cases, ranks them by real risk, explains each one in plain English with proof attached, and lets a human decide what to do.

Author: Vimala Mehrotra · Version October 2026 · Results generated 2026-10-19

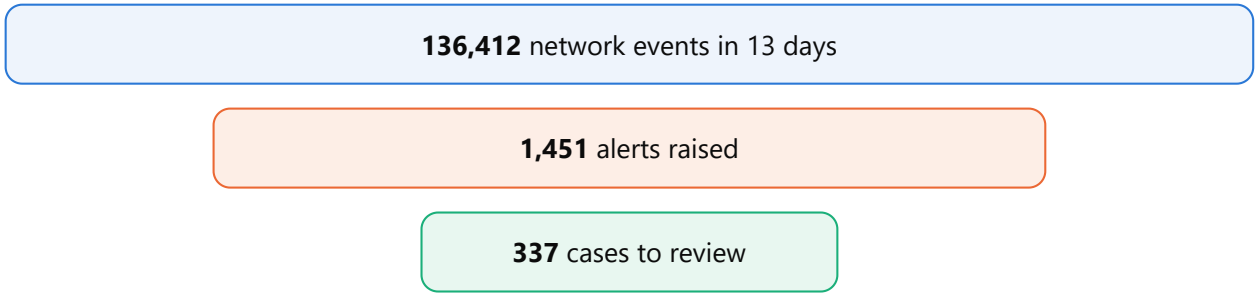
1. The problem it solves

Every company network produces an enormous number of events - every web page, every login, every device checking in. Security tools raise warnings on the suspicious ones, but they raise **so many** that analysts cannot read them all. Real attacks get lost in the noise, and people burn out.

SecureOps AI tackles this in three ways:

- **Fewer, better items to read.** Related warnings are merged into a single case, so one attack becomes one case instead of hundreds of alerts.
- **Most dangerous first.** Each case gets a 0-100 risk score that combines how sure we are it is an attack, how important the affected computer is, and whether it has known weaknesses that criminals are exploiting today.
- **Explained, with proof.** An AI assistant writes a short explanation in plain English. Every sentence points to the exact log lines it is based on, and a checker rejects anything that is not backed by evidence.

On real attack data, over 13 days the system had never seen:



97%	**77%**	**0.5%**	**100%**
of alarms were real attacks	fewer items for an analyst to read	of normal activity wrongly flagged	of AI sentences backed by evidence (327 checked)

> **Honest headline:** it is very accurate when it raises an alarm, but it notices about 33% of attack activity. Password-guessing attacks are caught well; quiet, single-connection attacks are mostly missed. Section 7 explains why.

2. How it works - the seven steps



Steps 1-6 run automatically every few seconds; step 7 always stays with a human.

Step	What happens, in plain words
1 Collect	Network events arrive continuously. Each event says which computer talked to which, on which "door" (port), for how long and how much data moved.
2 Map	The system learns which computers exist, what services they offer (web, file sharing, email...) and how many others depend on them. Busy, widely used servers are treated as more important. Owners can correct this with an inventory file.
3 Detect	Eight detection rules look for known attack patterns, and an AI model looks for anything unusual. Each produces *alerts* (section 4).
4 Group	Alerts that involve the same computer within two hours are joined into one *incident*, like puzzle pieces forming one picture. A scan, followed by a break-in attempt, followed by data theft from the same machine becomes one story.
5 Rank	Each incident gets a 0-100 score and a severity (Critical / High / Medium / Low) with a deadline: Critical 1 hour, High 4 hours, Medium 1 day, Low 3 days (section 5).
6 Explain	The AI assistant writes what happened, why it matters, what to check next and what is still unknown - citing the evidence for every sentence (section 6).
7 Respond	An analyst assigns an owner, approves actions (block an address, isolate a computer, mark as harmless) and closes the case. Every click is recorded in an audit trail. **Nothing is blocked automatically.**

3. Where the data comes from

Nothing in the system is made up. Every input is real and most of it is fetched live from public sources.

Source	What it is	Is it your network?
Dataset replay UWF-ZeekData24	Real network recordings made by the University of West Florida, who attacked their own test network and labelled every attack. About 191,000 connections over 18 days, replayed as if happening now.	No - their 2024 lab network (addresses 143.88.x.x). It guarantees real attacks to detect and lets us measure accuracy.
Live sensor	Zeek + Suricata running on a computer you control, sending what they see to the system every few seconds.	Only the network the sensor is connected to. In the current test setup it runs inside Docker on the laptop, so it sees container traffic only, not the home Wi-Fi.
Threat intelligence	abuse.ch Feodo Tracker (botnet servers), abuse.ch URLhaus (malware sites) and Spamhaus DROP (criminal networks), refreshed every 6 hours.	Public lists
Vulnerabilities	US National Vulnerability Database, CISA "known exploited" list and FIRST EPSS exploit probabilities.	Public lists
Attack knowledge	MITRE ATT&CK - the standard catalogue of 700+ attacker techniques.	Public

> **Is my network being attacked?** Incidents tagged *replay* are recorded attacks on someone else's lab. Incidents tagged *live* come from your sensor. To watch a real home or office network, the sensor must sit where the traffic passes - for example a Raspberry Pi connected to a router port that copies all traffic.

The replay's attack days and normal days were recorded in different weeks, so the system overlays them day by day (keeping each one's real time of day). This is stated wherever results are reported.

4. The detection models

Rules - known attack patterns

Rule	Fires when...	Attack type
Repeated connection attempts	one computer opens 10+ sessions to the same login service within 5 minutes (password guessing)	Credential Access
SSH login failures / success after failures	5+ failed remote logins, or a success right after many failures (a guessed password)	Credential Access / Initial Access
Port scan / host sweep	one computer probes 15+ doors on a machine or 25+ machines within 5 minutes (attackers mapping the network)	Reconnaissance
Lateral movement	one inside computer suddenly logs into 10+ other inside computers using admin tools	Lateral Movement
Large outbound transfer	more than 100 MB leaves for the internet in one connection	Exfiltration
Threat-intel match	any traffic to or from an address on a live blocklist	Command and Control
IDS signature	Suricata recognises a known attack pattern (it ships with ~53,000 of them)	Initial Access

The AI anomaly model - "this looks unusual"

Rules only catch what someone thought of in advance. The anomaly model (an *Isolation Forest*) learns, without being told what attacks look like, what normal behaviour is for each kind of computer during its first 48 hours. After that it scores every computer every hour. Imagine sorting a crowd by asking yes/no questions: a person who can be singled out in very few questions ("the only one wearing a red hat") is unusual. Computers that are easy to isolate in the same way - contacting far more machines or doors than usual, many failed connections, unusual amounts of data - get flagged, with the reasons spelled out (e.g. "distinct destinations = 6, typical 1").

All thresholds (10 attempts, 5 minutes, 100 MB...) are settings in `config.yaml`, not fixed in the code. They follow widely used defaults (fail2ban for password guessing, Zeek's scan policy for scans).

5. How cases are grouped and ranked

Grouping

Two alerts belong to the same case when they involve the same computer or address and happen within two hours of each other. Chains are followed: if A links to B and B links to C, all three are one case. Shared infrastructure that everyone talks to (like the company's name server) is deliberately ignored for linking, so unrelated alerts are not glued together. New alerts keep joining an open case while the attack continues.

The risk score (0-100)

Ingredient	Weight	Meaning
Threat confidence	45%	How sure the rules and model are. Several different kinds of evidence add up; three or more attack stages add a bonus.
Asset importance	25%	How critical the affected computer is (1-5), learned from traffic or set in the inventory.
Vulnerability exposure	20%	Whether the computer has known weaknesses, weighted by real-world exploitation (CISA list, EPSS). An attack signature matching a weakness the target really has counts as "confirmed exploitable".
Spread	10%	How many of your computers are involved.

Score 80+ is **Critical**, 60+ **High**, 40+ **Medium**, otherwise Low. On the test data the cases that really were attacks scored on average 39.4 versus 29.4 for false alarms, and 91% of the top 307 cases were real attacks - so ranking puts real problems first.

Notifications

When a new case appears or gets more serious, a pop-up appears on screen. High and Critical cases also trigger a red "Possible breach" banner on every page with a button that jumps straight to the investigation.

6. The AI investigation assistant

You can ask questions in everyday English on the **Investigate** screen. Behind each answer:

1. **Find the evidence.** The question is matched to cases, computer addresses, attack types or time words, and the relevant records are pulled from the database: alerts, raw log lines, computer details, vulnerability facts, attack technique descriptions and response checklists. Each piece has an ID such as `EVT-102212`.
2. **Write the answer.** A language model (free Groq service, model chosen automatically from what Groq currently offers) is told to use only that evidence and to end every sentence with the IDs it relied on. Without an AI key, a simpler built-in writer produces the answer from the same evidence.
3. **Check the answer.** A checker reads every sentence. A sentence with no citation, or citing an ID that was not in the evidence, is marked unsupported and shown to the analyst as such.

You: What is happening on my network right now and what should I do first?
SecureOps AI: Both hosts also generate high-volume repeated connection attempts ... that match the brute-force pattern [ALR-856, ALR-1010, PB-BRUTE]. **First action:** verify and contain the brute-force sources according to the PB-BRUTE playbook [PB-BRUTE] ...
openai/gpt-oss-120b · 100% of statements cite evidence

Measured reliability: across 20 real incidents the AI wrote 327 sentences; 100% cited only evidence that exists. An earlier run, with a shorter answer limit, scored 97.2% because some answers were cut off mid-sentence - the checker caught every one. Twenty incidents is a small sample, so this is a good sign rather than a guarantee.

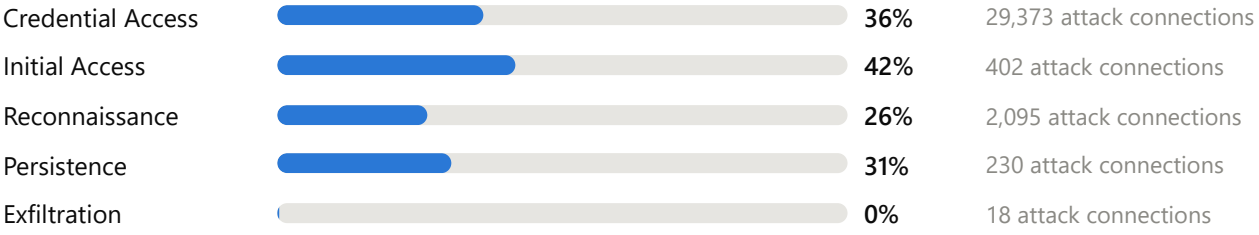
> **Privacy note:** when an AI key is configured, the evidence for a question (addresses, ports, times, alert text) is sent to the Groq service to generate the answer. Without a key, nothing leaves the system.

7. How well it works - measured on real data

The system was run on all 18 recorded days exactly as it runs live. Settings were sanity-checked on the first 5 days; the results below are from the **13 later days** that were never used for any decision. Accuracy is measured per computer per hour: "was this computer doing something malicious during this hour, and did we flag it?"

Detector	Precision alarms that were real	Recall attacks noticed	False alarm rate
Rules + AI model (what you use)	97%	33%	0.50%
Rules only	100%	32%	0.00%
AI anomaly model only	63%	2%	0.50%

Share of attack activity noticed, by attack type



"Noticed" = the computer-hour containing the attack was flagged. For the smaller categories part of this comes from the same computer also guessing passwords in that hour.

Where it falls short - and why

- **Quiet attacks are mostly missed.** Persistence, privilege escalation and exfiltration in this dataset are single, ordinary-looking file-sharing connections. Connection records alone (who, when, how much) cannot tell them apart from normal use; that needs the content of the traffic or endpoint data, which this dataset does not include.
- **Slow reconnaissance** (a few probes per hour) stays under standard scan thresholds; only the AI model catches part of it.
- **Two rules cannot be tested on this dataset** (threat-intel matches and data theft to the internet) because every machine in it is on one internal network. They were tested with live sensor traffic and automated tests.
- **Analyst time saved was not measured** with real analysts; the app records actual time-to-acknowledge and time-to-resolve once people use it.

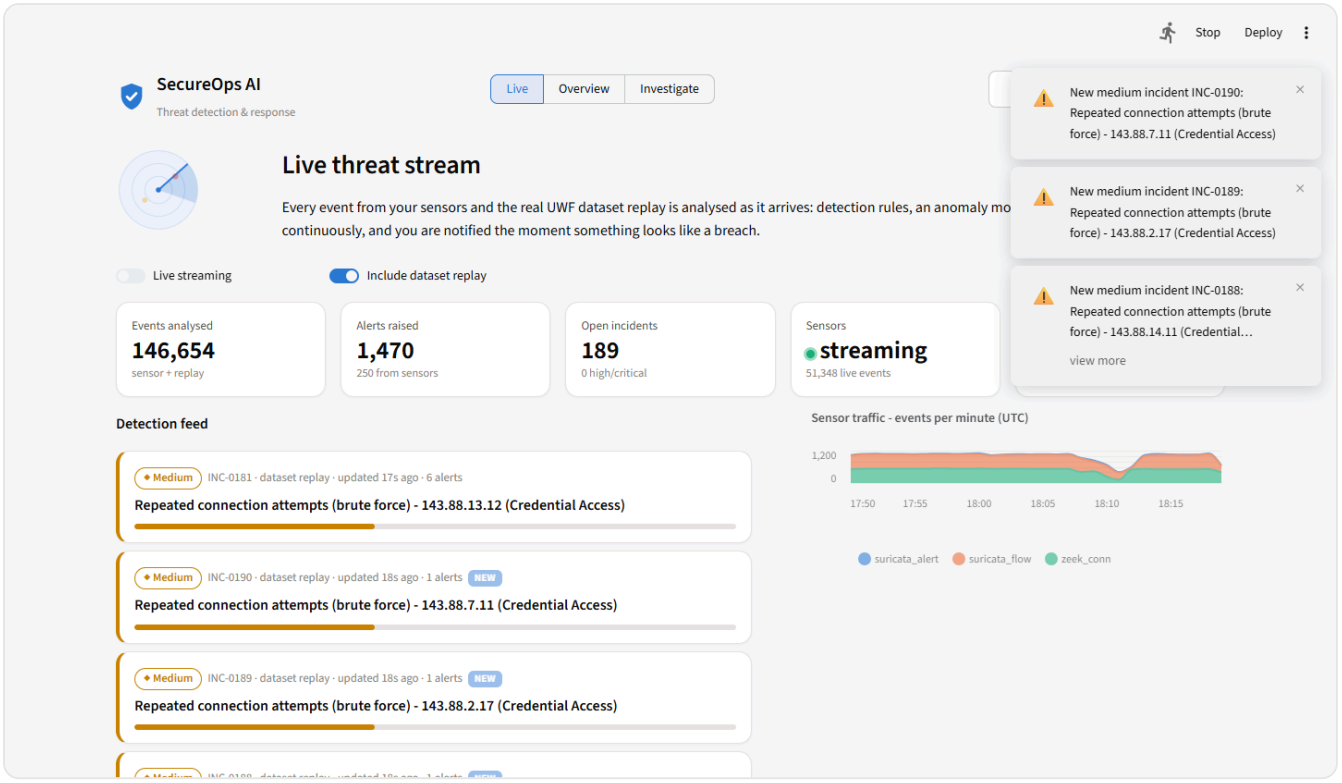
8. Using the app

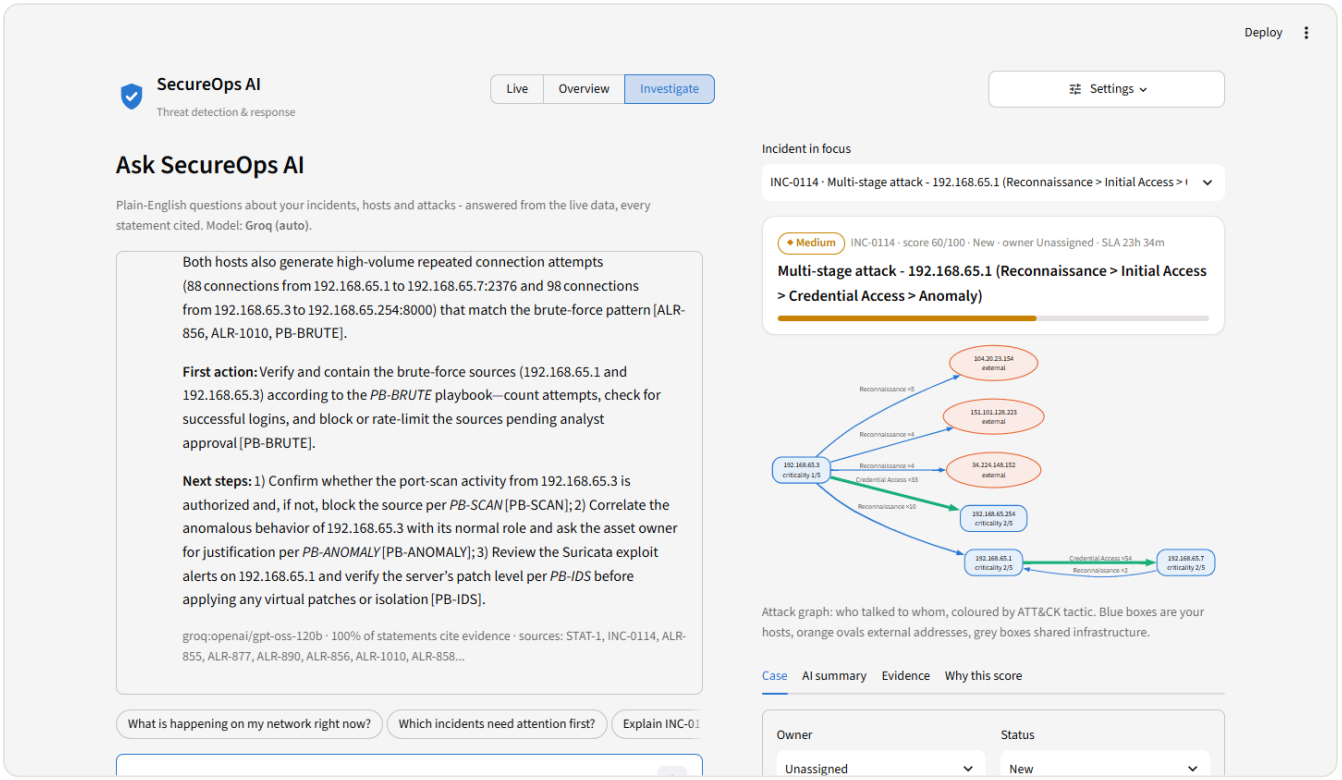
Live

The real-time screen: a feed of detections that updates every few seconds, pop-up alerts, sensor status, traffic chart and what the models are seeing.

Overview & Investigate

Overview shows totals, trends, the most targeted computers, the case list and measured accuracy. **Investigate** is the chat assistant next to an attack map and the case controls.





9. Safety, privacy and running it

- **Humans stay in charge.** Proposed actions (block, isolate, allow-list) are recorded for approval; nothing is executed automatically.
- **Everything is audited.** Every change of owner, status or note is logged with who did it and when.
- **Secrets stay secret.** API keys and database passwords live in a private secrets file or the host's secret store and are never written to the code or the database.
- **Monitor only networks you own** or are authorised to monitor.
- **Writes are protected.** Sending data to the system or changing cases through its programming interface needs a secret token.

Running it for free

Piece	Free service
The web app	Streamlit Community Cloud
AI explanations	Groq (free key)
Database that survives restarts	Neon PostgreSQL
Interface for sensors	Render
Sensor	Raspberry Pi / any Linux machine with Docker

Step-by-step instructions are in `DEPLOY.md`; technical details in `README.md`; full accuracy numbers in `reports/EVALUATION.md`.

10. Glossary

Alert	A single warning raised by one detection rule or the AI model, for example 'too many login attempts in 5 minutes'.
Incident / case	A group of related alerts that together describe one attack or event. This is what a person reviews.
Zeek	Free, widely used network-monitoring software. It writes one line for every connection: who talked to whom, on which port, how much data.
Suricata	Free intrusion-detection software. It compares traffic with tens of thousands of known attack patterns ('signatures').
MITRE ATT&CK	A public encyclopedia of attacker behaviour (e.g. 'Brute Force', 'Reconnaissance') used worldwide to label attacks.
CVE	A public ID for a known software weakness, e.g. CVE-2021-41773.
CVSS	A 0-10 severity score for a CVE.
CISA KEV	The US government's list of weaknesses that criminals are known to be exploiting right now.
EPSS	A probability (0-100%) that a weakness will be exploited in the next 30 days.
Threat intelligence	Public lists of addresses known to be malicious, such as botnet control servers.
Isolation Forest	A machine-learning method that spots behaviour which is unusual compared with everything else it has seen.
Precision	When the system raises an alarm, how often it is a real attack.
Recall	Of all the real attacks, how many the system noticed.
False positive	An alarm about something harmless.
SLA	The deadline for handling a case, set by its severity (e.g. Critical within 1 hour).
LLM	Large language model - the AI that writes plain-English explanations (here: a free Groq-hosted model).
Sensor	A small computer running Zeek and Suricata that watches a network and sends what it sees to SecureOps AI.

Credits

UWF-ZeekData24 dataset: University of West Florida (CC BY 4.0). Threat intelligence: abuse.ch, Spamhaus. Vulnerability data: NIST NVD, CISA, FIRST. Attack knowledge: MITRE ATT&CK. Network sensors: Zeek, Suricata (ET Open rules).